VIETNAMESE-GERMAN UNIVERSITY

Bachelor's Thesis Proposal

# A Case study on Enforcing Security and Privacy requirements using Tool-Object Level Access Protocol

Assessor: Dr. Hoang Nguyen
Co-assessor: To be decided

## 1 Motivation

Web applications that process personal data must satisfy different kinds of security requirement at once. For example, *fine-grained access control* requirements require applications to allow different users may see different views of some data. More recently, applications must also comply to *data protection* requirements such as *purpose limitation* and *consent*, i.e., personal data collected for one purpose may not be reused for an incompatible one, and some processing is lawful only when the data subject has consented [2, 3].

Recently, Amazon Web Services released Tool-Object Level Access Protocol (ToLAP) [1], an open-source framework that enforces access control at the data access point, i.e., where a system reads a data source. ToLAP decides access at the object granularity. ToLAP enforces confidentiality via hiding columns, filtering rows, masking fields, and capping result sizes so that a caller only ever receives the authorized subset of the data.

ToLAP additionally lets each data access to be tagged with a *purpose* from an administrator defined set. Although ToLAP is presented as a framework for the tools of AI agents, its enforcement model is independent of the consumer and applies equally to a conventional application.

## 2 Objective

The objective of this thesis is to showcase ToLAP usability through a case study. In this case study, we first develop a web application and then use ToLAP to enforce, at its data layer, three different classes of security and data protection requirement: (i) fine-grained access control, (ii) purpose limitation, and (iii) user consent.

The case study is chosen to be developing a *conventional* web application with simple functionality but more complex security and privacy requirements.

## 3 Tasks

1. Study the security and privacy requirements, including fine-grained access control, purpose limitation, and consent.
2. Study the Tool-Object Level Access Protocol (ToLAP), its specification, policy model, and development tool.
3. Design and implement the case study application according to the given functional, security, and privacy requirements.
4. Encode and enforce the security requirements with ToLAP.
5. Encode and enforce the privacy requirements with ToLAP.
6. Validate the correctness and performance of the integrated system against the specified requirements.
7. Document the design, implementation, and evaluation in the final report.

## 4 Deliverables

The following deliverables are due at the end of the project:

**Final report** Please have a look at the submission requirements in the following section. The final report should consist of an introduction, a (theoretical) background section, sections describing the work packages and their outcomes, and a conclusion. The report must be written in English.

**Source code** Complete, documented source code with a reproducible evaluation.

**Presentation** At the end of the thesis, a 20-minute presentation must be given in a thesis defense seminar. It should give an overview and discuss the most important highlights of the work.

## References


[1] Amazon Web Services. Introducing ToLAP: Object-level access control for AI agent tools. AWS Open Source Blog. https://aws.amazon.com/blogs/opensource/introducing-tolap-object-level-access-control-for-ai-agent-tools/; source code at https://github.com/awslabs/tolap. Accessed 2026-10-17.

[2] European Parliament and Council. Regulation (EU) 2016/679, 2016. https://eur-lex.europa.eu/eli/reg/2016/679/oj.

[3] National Assembly of the Socialist Republic of Vietnam. Law on personal data protection, law no. 91/2025/QH15, 2025. https://english.luatvietnam.vn/dan-su/law-on-personal-data-protection-law-no-91-2025-qh15-405135-d1.html.